

**UNIVERSIDAD COMPLUTENSE
DE
MADRID**

MASTER EN CIBERSEGURIDAD



ALUMNO: Darwin Marcani Rojas

PROFESOR: D. Javier Domínguez Gómez

España-Madrid

2025

Contenido

1. Modelado de amenazas STRIDE sobre infraestructura ficticia	4
1.2. Punto evaluable 1: Diseño del DFD	4
1.3. Punto evaluable 2: Identificación de amenazas con STRIDE	5
1.4. Punto evaluable 3: Propuesta de mitigaciones.....	8
1.5. Punto evaluable 4: Reflexión final y análisis del riesgo	12

Contenido de tablas

Tabla 1.	Spoofing	5
Tabla 2.	Denial of Service	5
Tabla 3.	Tampering.....	6
Tabla 4.	Repudiation.....	6
Tabla 5.	Information Disclosure	7
Tabla 6.	Elevation of Privilege	7
Tabla 7.	Denial of Service	8
Tabla 8.	Mitigación Spoofing.....	8
Tabla 9.	Mitigación Denial of Service.....	9
Tabla 10.	Mitigación Tampering	9
Tabla 11.	Mitigación Repudiation	10
Tabla 12.	Mitigación Information Disclosure.....	10
Tabla 13.	Mitigación Elevation of Privilege.....	11
Tabla 14.	Mitigación Denial of Service.....	11

Contenido de figuras

Figura 1.	Diseño DFD HydroSafe	4
------------------	----------------------------	---

1. Modelado de amenazas STRIDE sobre infraestructura ficticia

1.2. Punto evaluable 1: Diseño del DFD

El alumno debe diseñar un DFD que represente la arquitectura de una empresa ficticia de su elección. No hay mejor ni peor elección, sé creativo, sé imaginativo, algo razonable y que no sea ni minúsculo ni gigante, sentido común.

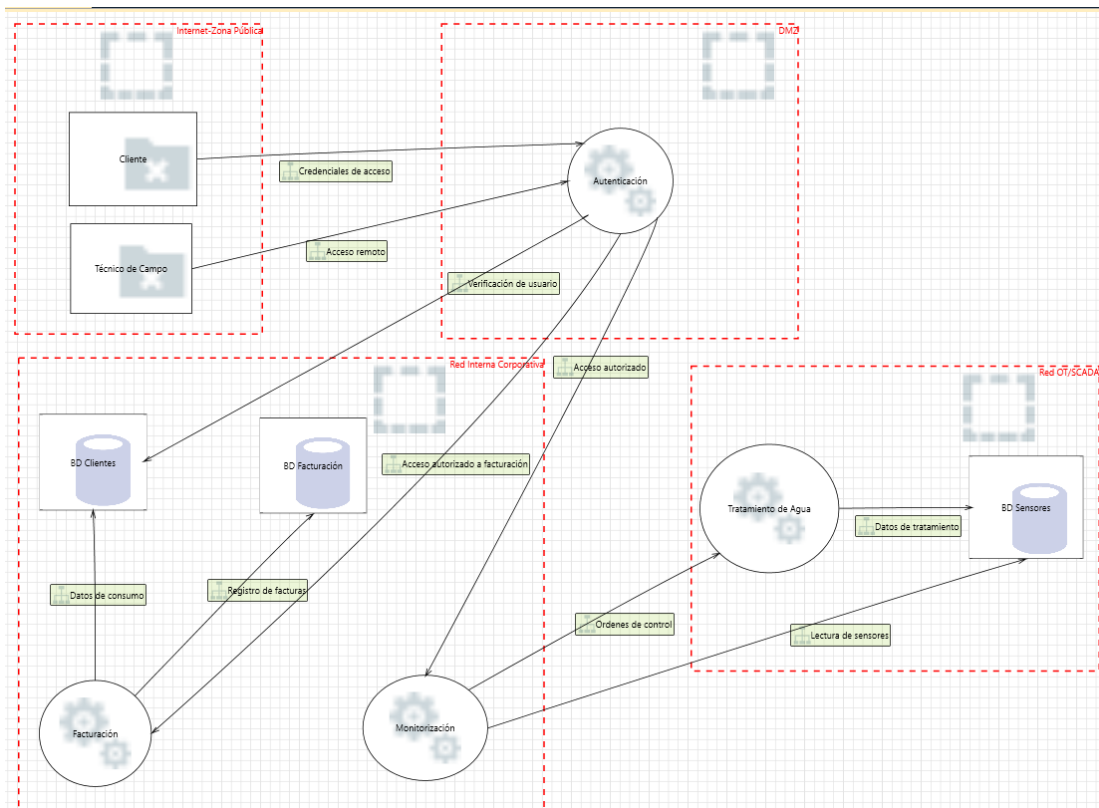


Figura 1. Diseño DFD HydroSafe

1.3. Punto evaluable 2: Identificación de amenazas con STRIDE

Identificación de Amenazas (STRIDE):

Campo	Contenido
Categoría STRIDE	Spoofing (Suplantación de identidad)
Componente afectado	Autenticación / Flujo "Acceso remoto"
Descripción	Un atacante suplanta la identidad del Técnico de Campo para acceder remotamente al sistema de control de HydroSafe S.A. El flujo de acceso remoto no implementa autenticación multifactorial ni VPN, lo que permite que credenciales robadas o débiles sean suficientes para obtener acceso al sistema SCADA y a los procesos de monitorización y tratamiento de agua.
Impacto esperado	Un atacante con acceso al sistema podría manipular parámetros críticos del tratamiento de agua, como niveles de cloro o dosificación química, comprometiendo la seguridad del suministro de agua a ciudadanos y empresas embotelladoras.

Tabla 1. Spoofing

Campo	Contenido
Categoría STRIDE	Denial of Service (Denegación de servicio)
Componente afectado	Proceso "Tratamiento de Agua" / Red OT/SCADA
Descripción	Un atacante satura o interrumpe el sistema de control del proceso de Tratamiento de Agua, dejando sin respuesta los PLCs que gestionan las válvulas, bombas y dosificación química. Al no existir un sistema de respaldo ni segmentación adicional dentro de la Red OT/SCADA, un ataque de denegación de servicio puede paralizar completamente el proceso de tratamiento y distribución del agua.
Impacto esperado	La interrupción del sistema de control provoca que las válvulas y bombas queden sin supervisión, lo que puede causar cortes en el suministro de agua a ciudadanos y empresas embotelladoras, o peor aún, una distribución de agua sin tratar correctamente por fallo en la dosificación química.

Tabla 2. Denial of Service

Campo	Contenido
Categoría STRIDE	Tampering (Manipulación de datos)
Componente afectado	BD Sensores / Flujo "Datos de tratamiento"
Descripción	Un atacante aprovecha la falta de sistemas de detección de intrusiones en la BD Sensores para manipular las lecturas de los sensores de la Red OT/SCADA, alterando los valores de cloro y otros químicos registrados, ocultando así niveles peligrosos en el agua distribuida.
Impacto esperado	La manipulación de lecturas de sensores puede provocar que el sistema de Monitorización tome decisiones incorrectas sobre el tratamiento del agua, distribuyendo agua con niveles inadecuados de químicos a ciudadanos y empresas embotelladoras.

Tabla 3. Tampering

Campo	Contenido
Categoría STRIDE	Repudiation (Repudio)
Componente afectado	BD Clientes / Flujo "Datos de consumo"
Descripción	La ausencia de registros de auditoría en la base de datos de clientes permite que un usuario malintencionado, ya sea interno o externo, realice acciones sobre los datos de consumo sin dejar rastro. Sin logs de auditoría no es posible determinar quién modificó, eliminó o accedió a los datos.
Impacto esperado	Un operador interno podría modificar registros de consumo de agua de clientes o empresas embotelladoras sin que exista forma de detectarlo o atribuírselo, lo que compromete la integridad de la facturación y la trazabilidad del sistema.

Tabla 4. Repudiation

Campo	Contenido
Categoría STRIDE	Information Disclosure (Divulgación de información)
Componente afectado	BD Clientes / Flujo "Verificación de usuario"
Descripción	Un atacante explota una vulnerabilidad de inyección SQL en el proceso de Autenticación para acceder de forma no autorizada a la BD Clientes de HydroSafe S.A., obteniendo datos personales, contratos y ubicaciones de la infraestructura de distribución de agua.
Impacto esperado	La exposición de datos personales de clientes y de la infraestructura crítica de distribución podría derivar en sanciones legales por violación de datos, además de proporcionar a una atacante información valiosa sobre la red de distribución de agua para planificar ataques más sofisticados.

Tabla 5. Information Disclosure

Campo	Contenido
Categoría STRIDE	Elevation of Privilege (Elevación de privilegios)
Componente afectado	Proceso "Monitorización" / Flujo "Acceso autorizado"
Descripción	El proceso de Monitorización se ejecuta con privilegios elevados sin aplicar el principio de mínimo privilegio. Un atacante que comprometa este proceso puede aprovechar esos privilegios para ejecutar código malicioso y acceder directamente a los parámetros de control del proceso de Tratamiento de Agua, modificando órdenes hacia los PLCs sin pasar por controles de autorización.
Impacto esperado	Un atacante con privilegios elevados en el sistema de Monitorización tendría control total sobre las órdenes enviadas al Tratamiento de Agua, pudiendo alterar la dosificación de químicos como el cloro, comprometiendo la seguridad del agua distribuida a ciudadanos y empresas embotelladoras.

Tabla 6. Elevation of Privilege

Campo	Contenido
Categoría STRIDE	Denial of Service (Denegación de servicio)
Componente afectado	Proceso "Autenticación" / DMZ
Descripción	Un atacante lanza un ataque de denegación de servicio contra el sistema de Autenticación ubicado en la DMZ, saturando el servidor con peticiones masivas hasta dejarlo inoperativo. Al ser el único punto de acceso al sistema, tanto operadores internos como técnicos de campo quedan sin acceso a los sistemas de monitorización y control.
Impacto esperado	La caída del sistema de Autenticación deja a HydroSafe S.A. sin capacidad de respuesta ante incidentes, imposibilitando el acceso de operadores al sistema SCADA y al proceso de Tratamiento de Agua, lo que puede derivar en una distribución de agua sin supervisión técnica.

Tabla 7. Denial of Service

1.4. Punto evaluable 3: Propuesta de mitigaciones

Mitigación - Spoofing

Campo	Contenido
Amenaza	Suplantación del Técnico de Campo
Mitigación técnica	Implementar autenticación multifactorial (MFA) obligatoria para todos los accesos remotos al sistema, combinada con una VPN corporativa cifrada para el Técnico de Campo.
Mitigación procedimental	Establecer una política de acceso remoto que obligue al Técnico de Campo a notificar previamente cada conexión, registrando hora, motivo y duración del acceso en un log de auditoría.

Tabla 8. Mitigación Spoofing

Mitigación - Denial of Service (Tratamiento de Agua)

Campo	Contenido
Amenaza	DoS al sistema de control de Tratamiento de Agua
Mitigación técnica	Implementar sistemas de control redundantes en la Red OT/SCADA, de manera que, si el sistema principal de control de PLCs es atacado, un sistema de respaldo tome el control automáticamente manteniendo la dosificación química dentro de parámetros seguros.
Mitigación procedimental	Establecer un protocolo de respuesta ante incidentes específico para ataques DoS en la Red OT/SCADA, que indique los pasos a seguir por los operadores cuando el sistema de control quede inoperativo, incluyendo activación manual de válvulas y parada segura del proceso.

Tabla 9. Mitigación Denial of Service

Mitigación - Tampering (BD Sensores)

Campo	Contenido
Amenaza	Manipulación de lecturas de sensores en BD Sensores
Mitigación técnica	Implementar un sistema de detección de intrusiones específico para la Red OT/SCADA que monitorice en tiempo real cualquier modificación anómala en las lecturas de los sensores, generando alertas automáticas cuando los valores se desvíen de los parámetros normales de operación.
Mitigación procedimental	Establecer una política de verificación cruzada donde los operadores de HydroSafe contrasten periódicamente las lecturas digitales de los sensores con mediciones físicas manuales en campo, detectando posibles manipulaciones en los datos almacenados en la BD Sensores.

Tabla 10. Mitigación Tampering

Mitigación - Repudiation (BD Clientes)

Campo	Contenido
Amenaza	Falta de auditoría en BD Clientes
Mitigación técnica	Implementar un sistema de logging y auditoría completa en la BD Clientes que registre automáticamente todas las acciones realizadas, incluyendo usuario, fecha, hora, tipo de acción y datos modificados, almacenando estos registros en un sistema separado e inalterable.
Mitigación procedimental	Establecer una política de revisión periódica de los logs de auditoría por parte del responsable de seguridad de HydroSafe, realizando revisiones semanales para detectar accesos o modificaciones no autorizadas en los datos de consumo de clientes.

Tabla 11. Mitigación Repudiation

Mitigación - Information Disclosure (BD Clientes)

Campo	Contenido
Amenaza	Inyección SQL para acceso no autorizado a BD Clientes
Mitigación técnica	Implementar validación y sanitización de todas las entradas de datos en el proceso de Autenticación para prevenir inyecciones SQL, utilizando consultas parametrizadas y un Aplicación Web Firewall que detecte y bloquee patrones de ataque SQL automáticamente.
Mitigación procedimental	Establecer una política de revisión de código seguro donde todo nuevo desarrollo o actualización del sistema de Autenticación pase por un proceso de auditoría de seguridad antes de ser desplegado en producción, verificando específicamente vulnerabilidades de inyección SQL.

Tabla 12. Mitigación Information Disclosure

Mitigación - Elevation of Privilege (Monitorización)

Campo	Contenido
Amenaza	Escalada de privilegios en proceso de Monitorización
Mitigación técnica	Aplicar el principio de mínimo privilegio en el proceso de Monitorización, configurando cuentas de servicio con permisos estrictamente necesarios para su función, implementando además una segmentación de roles que separe los permisos de visualización de los de control sobre los PLCs del Tratamiento de Agua.
Mitigación procedimental	Establecer una política de revisión trimestral de permisos y privilegios de todos los usuarios y procesos del sistema de HydroSafe, revocando inmediatamente cualquier privilegio que no sea estrictamente necesario para la función asignada.

Tabla 13. Mitigación Elevation of Privilege

Mitigación - Denial of Service (Autenticación)

Campo	Contenido
Amenaza	DoS al sistema de Autenticación en la DMZ
Mitigación técnica	Implementar un sistema de limitación de peticiones y un balanceador de carga en la DMZ que distribuya el tráfico entrante, bloqueando automáticamente IPs que superen un umbral de peticiones por segundo, combinado con un sistema de detección de ataques DoS que active contramedidas automáticas.
Mitigación procedimental	Establecer un plan de continuidad de negocio que defina un procedimiento de acceso de emergencia al sistema de control de HydroSafe en caso de caída del sistema de Autenticación, permitiendo a operadores autorizados acceder físicamente a los sistemas críticos desde la red interna sin depender del portal de autenticación.

Tabla 14. Mitigación Denial of Service

1.5. Punto evaluable 4: Reflexión final y análisis del riesgo

Principales riesgos detectados

Tras el análisis realizado sobre la infraestructura de HydroSafe, los riesgos más críticos identificados son la suplantación de identidad del Técnico de Campo por la ausencia de MFA y VPN, y la manipulación de los sistemas de control industrial como los PLCs que gestionan la dosificación de químicos en el agua. Estos riesgos son especialmente graves al tratarse de infraestructuras críticas para la empresa, donde un ataque exitoso no solo compromete datos, sino que puede afectar directamente a la salud pública de ciudadanos y empresas embotelladoras, y puede ser un golpe duro para empresa en su reputación.

Elementos críticos de la arquitectura

Los elementos más vulnerables de la arquitectura son el proceso de Autenticación como único punto de entrada al sistema, la Red OT/SCADA por la falta de segmentación adicional y el uso de protocolos industriales sin cifrado, y la BD Sensores cuyos datos son fundamentales para garantizar la calidad del agua distribuida. La ausencia de sistemas de detección de intrusiones en la red industrial representa una debilidad estructural importante.

Límites del análisis y posibles mejoras

El análisis se ha realizado sobre una arquitectura simplificada con el objetivo de ilustrar los principales vectores de ataque. En un entorno real, el análisis debería ampliarse considerando la seguridad física de las instalaciones, los proveedores externos y la cadena de suministro del software industrial. Como mejoras futuras se podría ampliar el DFD incluyendo más componentes OT como RTUs e historiadores de datos, realizar un análisis de riesgo cuantitativo y aplicar normativas específicas de infraestructura crítica como IEC 62443.